

Recommandations pour M@Banque

- Introduction
- Etape 1
- Etape 2
- Etape 3
- Etape 4
- Conclusion

Introduction

Ce rapport présente une analyse complète des risques liés à la protection des données personnelles et une veille technologique pour garantir la sécurité des systèmes d'information. À travers une étude de cas et des exercices pratiques, nous explorons les outils et méthodes permettant d'identifier les vulnérabilités, d'évaluer les risques, et de proposer des mesures correctives adaptées. Une attention particulière est portée sur les recommandations pour M@Banque suite à un incident de défiguration.

Étape 1 : Présentation du Contexte et des Outils

Contexte de l'Étude

L'objectif est d'analyser les risques liés au traitement des données personnelles dans le cadre d'une étude de marché menée par CentreCall. Les données collectées incluent des informations personnelles, des réponses à un questionnaire, des enregistrements audio, et les résultats finaux de l'étude.

Outils Utilisés

PIA (Protection des Données - Analyse d'Impact) : Pour évaluer les risques liés à la protection des données.

OWASP ZAP et W3AF : Pour détecter les vulnérabilités web.

Google Safe Browsing et URLVoid : Pour vérifier la sécurité et la réputation des sites web.

Étape 2 : Analyse des Risques et Mesures Correctives

Identification des Risques

Risque	Conséquences Potentielles	Mesures Correctives
Accès illégitime aux données	Interception ou vol d'informations pendant les communications ou le stockage.	Chiffrement des échanges, identifiants sécurisés, cloisonnement des réseaux.
Modifications non désirées	Erreurs de saisie ou modifications accidentelles des données.	Journalisation des accès, validation manuelle des saisies, sauvegardes régulières.
Disparition de données	Panne matérielle, suppression accidentelle ou perte de support.	Sauvegardes sur plusieurs serveurs, copies externes des fichiers d'étude.

Cartographie des Risques

Risque	Gravité	Vraisemblance	Positionnement
Accès illégitime aux données	Maximale	Importante	(A)
Modifications non désirées	Importante	Limitée	(M)
Disparition de données	Importante	Négligeable	(D)

Légende :

(A) : Gravité maximale, vraisemblance importante.

(M) : Gravité importante, vraisemblance limitée.

(D) : Gravité importante, vraisemblance négligeable.

Étape 3 : Veille Technologique et Outils d'Audit

Objectifs de la Veille Technologique

Objectifs	Sources d'Information	Exemple	Évaluation
Vérifier la crédibilité des auteurs	Crédibilité de l'auteur	ANSSI	4
S'assurer de la fiabilité des sources	Fiabilité de la source	Site d'actualité technique	4
Garantir l'objectivité des informations	Objectivité de l'information	Données techniques	3
Valider l'exactitude des informations	Exactitude de l'information	Alertes et vulnérabilités	4
Maintenir l'actualité des informations	Actualité de l'information	Mises à jour en temps réel	4
Sélectionner des informations pertinentes	Pertinence de l'information	Exemple de site bancaire sécurisé	4

Outils de Veille Technologique

Objectifs	Sources d'Information	Exemple	Évaluation
Vérifier la crédibilité des auteurs	Crédibilité de l'auteur	ANSSI	4
S'assurer de la fiabilité des sources	Fiabilité de la source	Site d'actualité technique	4
Garantir l'objectivité des informations	Objectivité de l'information	Données techniques	3
Valider l'exactitude des informations	Exactitude de l'information	Alertes et vulnérabilités	4
Maintenir l'actualité des informations	Actualité de l'information	Mises à jour en temps réel	4
Sélectionner des informations pertinentes	Pertinence de l'information	Exemple de site bancaire sécurisé	4

Outils d'Audit de Sécurité

Outil	Description/Avantages
OWASP ZAP	Outil gratuit pour scanner les vulnérabilités web en interceptant les requêtes. Facile à utiliser.
W3AF	Framework open-source pour auditer et attaquer les applications web. Permet de repérer diverses vulnérabilités.
Burp Suite	Fonctionne comme un intercepteur entre un navigateur et une application web. Très complet pour les tests.
Nessus	Scanner de vulnérabilités pour détecter les failles d'infrastructure. Donne une vue d'ensemble des risques.

Analyse de Sécurité du Site Web

Critères d'Analyse	Google Safe Browsing	URLVoid
Malware	Aucun contenu suspect détecté.	Aucun malware détecté.
Spam	Aucun contenu suspect détecté.	Aucun spam détecté.
Phishing	Aucun contenu suspect détecté.	Aucun phishing détecté.
Taux de réputation	Réputation positive selon Google.	Réputation positive dans plusieurs bases de données.
Listes noires	Non listé.	Non listé dans les bases de données de listes noires.

Exercice 5 : Note à l'Attention de Mme Schmitt

Madame Schmitt,

Suite à l'incident récent de défiguration du site de M@Banque, il est essentiel de rétablir la confiance de nos clients et de garantir leur sécurité en ligne. Voici une proposition structurée pour répondre à cette situation :

Vérification Continue de l'Intégrité du Site Nous recommandons la mise en place d'une solution de vérification continue de l'intégrité du site, utilisant des outils d'audit de sécurité reconnus :OWASP ZAP : Pour détecter les vulnérabilités web et les failles potentielles.W3AF : Pour auditer les applications web et identifier les risques de sécurité.

Contrôles Réguliers de Sécurité Pour renforcer la transparence et la confiance, nous proposons d'utiliser des outils accessibles au public pour vérifier la sécurité du site :

Google Safe Browsing : Outil officiel de Google pour vérifier l'absence de malware, de spam ou de phishing.

URLVoid : Pour consulter plusieurs bases de données et confirmer que le site n'est pas listé comme malveillant.Communication Transparente avec les Clients Pour rassurer les clients, nous suggérons d'envoyer une communication claire et concise, incluant :

Une explication simple de l'incident et des mesures prises pour le résoudre.

Un lien vers Google Safe Browsing pour qu'ils puissent vérifier eux-mêmes la sécurité du site. Une insistance sur la transparence : "Nous n'avons rien à cacher et souhaitons vous prouver que notre site est sécurisé."

Mise en Place d'une Veille Technologique Pour prévenir de futurs incidents, nous recommandons de :

Documenter chaque modification apportée au site (mises à jour, correctifs, audits). Publier régulièrement un rapport de sécurité pour informer les clients des actions entreprises.

Cordialement.

Conclusion

Ce compte rendu a permis de comprendre l'importance de l'outil PIA pour analyser les risques liés au traitement des données personnelles, ainsi que l'utilité des outils de veille technologique pour garantir la sécurité des systèmes d'information. Les risques majeurs identifiés (accès illégitime, modifications non désirées, disparition de données) ont été analysés, et des mesures correctives ont été proposées.